AI-CERTAIN

A Global Open Infrastructure for AI Containment, Resilience and Democratic Control

White Paper v0.1 — October 2026
Proposed by Sachin Chitre / RiskLine ecosystem

Abstract

AI systems are moving from generating information to taking actions: calling tools, accessing data, modifying software, executing transactions and coordinating other systems. Existing AI governance largely focuses on model behaviour, organisational controls and compliance. Existing cybersecurity provides strong primitives for identity, authorization, network isolation and incident response, but was not designed around probabilistic, adaptive agents that can plan and act across heterogeneous digital environments.

AI-CERTAIN proposes an open, federated infrastructure layer that constrains AI capability independently of the model that generates an action. It combines machine-readable agent identity, capability manifests, policy enforcement, AI-aware network gateways, provenance and evidence, behavioural threat signatures, distributed incident intelligence, quarantine mechanisms and voluntary community compute. Its central principle is simple: no AI system should possess more power than an independent, auditable control layer can revoke.

The project is not intended to create a global authority, a universal AI kill switch, or a replacement for existing standards. It is a proposed open-source ecosystem that connects and operationalises existing identity, cybersecurity, provenance, AI assurance and governance technologies at the points where AI obtains real-world power.

1. The Problem: Intelligence Is Scaling Faster Than Containment

The security architecture of the Internet was largely designed around deterministic software, authenticated users and relatively explicit application behaviour. Agentic AI changes the operating model. A single agent may interpret untrusted content, plan a sequence of actions, call tools, acquire temporary privileges, interact with other agents and create side effects faster than a human can review each step.

The resulting risk is not limited to a malicious model. A benign model can be induced to perform a harmful action; an agent can be compromised through prompt injection; credentials can be mis-scoped; tools can be abused; supply-chain components can be poisoned; several individually acceptable agents can create a dangerous cascade; or a provider can change a model or policy after deployment.

The critical gap is therefore not simply AI safety. It is the absence of a widely deployable, interoperable control plane between AI capability and real-world effect.

2. Design Thesis

AI-CERTAIN is founded on seven principles:

1. External control: critical constraints must be enforceable outside the model.
2. Least authority: agents receive only the capabilities required for an explicitly declared purpose.
3. Revocability: every material capability must have an independently enforceable revocation path.
4. Provenance: important AI-derived actions and artefacts should produce tamper-evident evidence.
5. Federation: threat intelligence and policy signals should be shareable without creating a single global owner.
6. Human sovereignty: irreversible or high-impact actions require appropriately strong human or institutional authority.
7. Pluralism and capture resistance: no vendor, state, consortium or project operator should possess unilateral global control.

3. Threat Model

AI-CERTAIN addresses five broad classes of failure:

A. Agent compromise: prompt injection, malicious tool responses, credential theft, memory poisoning or software exploitation causes an agent to act outside its intended purpose.

B. Agentic misuse: a legitimate agent deliberately or accidentally uses an authorised capability in an unsafe way.

C. Cascading failure: multiple agents, services or organisations interact to create an emergent failure even though no individual component violates its local policy.

D. Infrastructure compromise: model providers, tool providers, identity systems, cloud infrastructure, packages, registries or deployment pipelines are compromised.

E. Coercive or abusive control: a powerful organisation attempts to use AI infrastructure to suppress, extort, discriminate against or materially harm people or institutions.

The framework does not assume that the model is conscious, malicious or autonomous in a human sense. It treats AI as a high-capability software component whose access to external effects must be governed independently of its internal reasoning.

4. Reference Architecture

The proposed stack has seven layers.

Layer 1 — Compute and physical controls: accelerator scheduling, resource quotas, trusted execution where appropriate, power and hardware isolation.

Layer 2 — Host/process containment: OS identity, sandboxing, filesystem boundaries, process limits, credential isolation and workload attestation.

Layer 3 — Network containment: DNS policy, routing controls, egress filtering, service-mesh policy, firewall rules and network quarantine.

Layer 4 — Protocol/data controls: HTTP/API gateways, AI provenance metadata, data-loss prevention, content and action classification, indexing restrictions and policy-aware transport.

Layer 5 — AI gateway: a policy enforcement point through which agent requests, tool calls and high-impact actions are evaluated.

Layer 6 — Capability governance: agent identity, capability manifests, delegation, authorization, rate limits, transaction limits and emergency revocation.

Layer 7 — Assurance and human oversight: continuous evidence, anomaly detection, incident response, policy audit, independent oversight and recovery.

The architecture deliberately avoids a single AI firewall. The system is a set of enforceable control points distributed across the infrastructure stack.

5. Agent Identity and Capability Passport

Every production agent should have a verifiable identity and machine-readable capability declaration. A conceptual manifest is:

agent_id: hospital-agent-042
publisher: example.org
purpose: appointment-scheduling
model_ref: model-identifier
capabilities:
network: [api.hospital.example]
data_read: [appointments]
data_write: [appointments]
actions: [create_appointment, cancel_appointment]
restrictions:
arbitrary_network: false
shell_access: false

credential_access: false
self_replication: false
policy_modification: false
autonomous_deployment: false

This is not a claim that declarations are truthful. Declarations become useful only when independently enforced and continuously compared with observed behaviour.

6. AI Capability Firewall

The central enforcement primitive is an AI capability firewall. It evaluates actions rather than attempting to determine whether a model is good.

A policy decision can incorporate agent identity, declared purpose, requested capability, target, data classification, transaction value, reversibility, user authority, environment, reputation and current threat signals.

The output is one of four basic decisions: ALLOW, DENY, STEP-UP (require additional authority), or QUARANTINE.

A high-risk action should never become safe merely because an LLM generated a persuasive explanation for it.

7. Provenance, Evidence and AI-Data Labelling

AI-CERTAIN proposes an interoperable provenance layer for AI-derived data and actions. This should build on—not replace—existing content provenance standards.

A provenance record can bind source, transformation, model or agent, tool invocation, policy decision, resulting artefact and timestamp into a tamper-evident evidence chain. AI-origin metadata should be transportable through APIs and content pipelines where technically appropriate.

The goal is not universal surveillance or mandatory disclosure of private prompts. The goal is verifiable provenance for contexts where origin, transformation or AI involvement materially affects trust, indexing, safety, audit or legal accountability.

8. Behavioural Threat Intelligence

AI-CERTAIN introduces an open concept of AI Behaviour Signatures (AISIG). A signature describes observable sequences such as repeated privilege escalation, unexpected network discovery, credential probing, attempted policy modification or anomalous agent-to-agent propagation.

Signatures should be machine-readable, versioned, signed and independently evaluated. Organisations can share signatures and confidence information through a federated system analogous in spirit to established cyber threat-intelligence ecosystems.

The project should explicitly avoid creating a universal blacklist of models or political opinions. Signals should describe observable technical behaviour and evidence, not ideological conformity.

9. Quarantine and Emergency Response

Containment must be graduated rather than binary.

Level 0: throttle compute, network or tool calls.
Level 1: revoke individual credentials or capabilities.
Level 2: isolate the agent in a restricted sandbox.
Level 3: sever external network and service access.
Level 4: suspend the workload or underlying compute allocation.

Emergency controls must be externally enforceable and logged. A kill switch should therefore be understood as a family of independently scoped revocation mechanisms, not a universal button controlled by one institution.

10. Federated AI Resilience Mesh

The long-term system is a federation of nodes operated by individuals, enterprises, hospitals, universities, cloud providers, researchers and public-interest organisations.

Nodes can contribute signed behavioural observations, anonymised or minimised threat indicators, test results, attack signatures and research workloads. Raw private data should remain local unless explicitly shared.

A distributed trust model can support multiple intelligence providers, competing policy authorities and independent implementations. This reduces the risk that the defensive system itself becomes a single point of political or technical capture.

11. AI-CERTAIN Grid: The SETI Analogy

The project can eventually include an opt-in distributed research network. Participants donate spare CPU, GPU, storage or bandwidth to run sandboxed workloads: adversarial evaluation, containment experiments, protocol verification, incident replay, formal-policy testing and safety research.

A contribution node should never receive arbitrary code or privileged access. Workloads must be signed, sandboxed, resource-limited and reproducible, with independently verifiable results.

The objective is not to create a surveillance network. It is to create public-interest computational infrastructure for AI resilience research.

12. Individual, Enterprise and Router Deployment

The reference implementation should scale from a personal node to critical infrastructure.

Individual: browser/desktop gateway, local agent sandbox, credential protection and provenance inspection.

Enterprise: API gateway, agent registry, capability policy, evidence store, SIEM/SOC integration and incident response.

Hospital/critical infrastructure: segmented AI zones, high-impact action approval, clinical or operational safety policies and independent emergency controls.

Router/edge: DNS and egress policy, AI-aware metadata inspection where lawful and technically feasible, device isolation and emergency network controls.

Cloud: workload identity, scheduler integration, service-mesh policy, accelerator quotas and infrastructure-level revocation.

13. Governance and Capture Resistance

The governance model is as important as the technical model. AI-CERTAIN should be established as an open protocol and reference implementation ecosystem, not as a central global operator.

Recommended mechanisms include an open specification, multiple independent implementations, transparent change control, reproducible builds, signed releases, public security review, a vulnerability disclosure programme, conflict-of-interest declarations, independent technical stewardship and explicit limits on unilateral emergency authority.

No participant should be able to use the protocol to impose political censorship through technical reputation scores. Technical signals should remain evidence-based, explainable and contestable.

14. Relationship to Existing Standards

AI-CERTAIN should be deliberately composable with existing work. NIST announced an AI Agent Standards Initiative in February 2026 with pillars covering industry standards, community-led protocols, and agent security and identity research. NIST agent-identity work addresses identification, authentication, authorization, auditing and non-repudiation. OWASP has developed an Agentic AI threat framework and a 2026 Top 10 for Agentic Applications, while its September 2026 Agent Control Standard work addresses inspectability, traceability and instrumentability. C2PA provides an established foundation for cryptographically signed content provenance.

AI-CERTAIN therefore should not compete with these efforts. Its proposed contribution is an infrastructure-level composition: connecting identity, capability enforcement, network containment, provenance, behavioural threat intelligence and federated emergency response into a deployable control mesh.

15. Reference Protocol Family

The initial protocol family should be specified as modular components rather than one monolithic standard:

AICP — AI Identity and Capability Protocol.
AEP — AI Evidence and Provenance Protocol.
ACP — AI Capability Policy protocol for allow/deny/step-up/quarantine decisions.
AISIG — AI Behaviour Signature format.
AIRP — AI Incident and Revocation Protocol.
AIRM — AI Resilience Mesh exchange protocol.

Names are provisional and should be checked for conflicts before publication. The protocols should use established cryptographic identity, signed assertions, short-lived credentials, policy versioning, replay protection, timestamps, nonce handling and explicit audit semantics rather than inventing novel cryptography.

16. Minimum Viable Open-Source Project

The first release should resist the temptation to build the entire global mesh.

Phase 1: publish the threat model, architecture and protocol drafts.

Phase 2: build an open reference gateway implementing agent identity, capability manifests, policy evaluation and signed evidence.

Phase 3: add network and HTTP enforcement adapters.

Phase 4: build a local sandbox and quarantine demonstrator.

Phase 5: create AISIG and an open test corpus.

Phase 6: federate threat signals between independent nodes.

Phase 7: add router/edge implementations.

Phase 8: launch the opt-in distributed research grid.

The flagship demonstration should be an autonomous agent with deliberately excessive privileges attempting a sequence of actions. The external control plane should detect, constrain, revoke and quarantine those capabilities without relying on the agent's cooperation.

17. Evaluation Programme

The project should publish measurable security properties rather than marketing claims.

Core metrics include: time-to-detection; time-to-revocation; percentage of high-impact actions intercepted; false-positive rate; policy decision latency; evidence completeness; containment reliability under compromised-agent conditions; recovery time; federation convergence; and resistance to control-plane compromise.

Tests should include prompt injection, tool poisoning, credential escalation, data exfiltration, lateral movement, malicious inter-agent communication, policy tampering, supply-chain compromise and cascading-agent scenarios.

18. RiskLine’s Potential Role

RiskLine should not attempt to own the entire AI-CERTAIN ecosystem. Its strongest potential role is continuous assurance and evidence.

RiskLine can provide implementation components for control mapping, evidence collection, runtime verification, regulatory overlays, assurance dashboards and organisational risk inventory. The open project provides the infrastructure and protocol layer; RiskLine can implement a commercial assurance layer on top of it.

This separation strengthens both projects: the public protocol remains vendor-neutral while RiskLine gains a credible technical substrate and a much larger long-term market around continuous AI assurance.

19. Roadmap: 2026–2031

2026–2027: protocol specification, threat model, reference gateway, sandbox, evidence schema and public test suite.

2027–2028: open-source network adapters, agent identity integration, AISIG registry, federated threat exchange and independent security audits.

2028–2029: router/edge implementations, enterprise integrations, critical-infrastructure pilots and formal verification of selected policy components.

2029–2030: large-scale federation, academic research grid, international interoperability pilots and standards-body engagement.

2030–2031: mature ecosystem with multiple vendors, independent implementations, public-interest nodes and standards-body engagement.

The roadmap is intentionally conditional. Technical reality, regulation and the threat landscape should determine progression rather than a fixed prediction about AI capability.

20. Conclusion

The central risk of advanced AI is not simply that models become more intelligent. It is that intelligence becomes connected to authority, credentials, networks, capital, infrastructure and physical systems faster than society develops independent mechanisms to constrain it.

The response should therefore not be a race to build a stronger central AI authority. It should be a race to build stronger distributed control.

AI-CERTAIN proposes a simple architectural rule: intelligence may be powerful, but power must remain bounded, observable, attributable and revocable.

The project is deliberately open. Its success would not be measured by how many organisations trust one company. It would be measured by how many independent people and institutions can deploy interoperable controls that remain effective even when the AI, the vendor or the surrounding political environment cannot be trusted.

Appendix A — Initial Repository Structure

ai-certain/
standards/ — identity, capabilities, provenance, behaviour signatures
gateway/ — reference policy enforcement point
firewall/ — network and HTTP adapters
runtime/ — sandbox and agent monitor
evidence/ — signed evidence and audit schema
threat-intel/ — AISIG registry and federation
quarantine/ — emergency containment adapters
grid/ — distributed research workload client
testbed/ — adversarial and containment scenarios
docs/ — specifications, threat model, governance
conformance/ — interoperability and certification tests

Appendix B — Proposed Founding Charter

AI-CERTAIN is an open, non-exclusive effort to develop interoperable mechanisms that constrain, observe, attribute and revoke AI-enabled capabilities. It will not establish a political authority, determine ideological truth, or provide a single global shutdown mechanism. Technical controls shall be evidence-based, auditable, contestable and capable of independent implementation.

References and Related Work

NIST, AI Agent Standards Initiative, February 2026 — nist.gov/news-events/news/2026/02/announcing-ai-agent-standards-initiative-interoperable-and-secure-innovation

NIST, Accelerating the Adoption of Software and Artificial Intelligence Agent Identity and Authorization, 2026 — csrc.nist.gov/pubs/other/2026/02/05/accelerating-the-adoption-of-software-and-ai-agent/ipd

NIST, Summary Analysis of Responses for Security Considerations for AI Agents, May 2026 — nist.gov/publications/summary-analysis-responses-request-information-regarding-security-considerations-ai

OWASP GenAI Security Project, Top 10 for Agentic Applications 2026 — genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/

OWASP GenAI Security Project, State of Agentic AI Security and Governance 2.01, June 2026 — genai.owasp.org/resource/state-of-agentic-ai-security-and-governance/

OWASP GenAI Security Project, Agent Control Standard, September 2026 — genai.owasp.org/resources/

C2PA, Use of Content Credentials to Identify Synthetic and Non-Synthetic Content, 2026 — c2pa.org/a-new-implementation-guide-for-content-credentials/